

PARAMA CRM — Work Done & Next-Step Plan

A handoff for the lead developer · Prepared 2026-08-18 · Please read Part 3 and reply with your decisions

Summary. We prepared PARAMA CRM for the client demo. We did a full security audit. We fixed about 60 bugs and security holes across 49 files. We tested the fixes. The app is now safer and more stable. This document lists what we changed. It also proposes a plan to make the app simpler for the client: the product has about 90 features, and we want to show only about 10. We need your decision on which features to keep and which to hide.

Part 1 — What we already did DONE & VERIFIED

1a. Security audit and fixes (complete)

We reviewed every server endpoint. Our custom WhatsApp code was clean. The serious holes were in the open-source base. We closed them. Two holes were confirmed exploitable on the demo box and are now confirmed closed by a live re-test.

Hole	Fix	Status
Any user could create a "Won" deal owned by another user (<code>create_deal</code>)	Added a create-permission check and an owner-spoof block	closed, live-tested
A guest could read site info + a security token (<code>developer_mode</code> was on)	Turned developer mode off; endpoint now refuses	closed, live-tested
A sales user could send WhatsApp from the brand to ANY number	Send now needs write permission and checks the recipient matches the lead	closed
Stored XSS from an incoming email (script in the email body)	Email body is sanitised and the preview frame is sandboxed	closed
Many endpoints missing permission checks (assignments, call logs, contacts, notes, tasks, quick filters, email accounts, lead-sync)	Added the correct permission or role checks to each	closed
Server request forgery through the exchange-rate date	The date is now validated before use	closed
Twilio webhook trusted an identifier, not a signature; Exotel put secrets in the URL	Real signature check added; secrets moved to headers	closed

Full detail with file names is in `demo-package/AUDIT-REPORT.md`.

1b. Reliability and bug fixes

- **Chat pane no longer crashes** on empty or media messages, or on a reply to an app-created message.
- **The reply box no longer loses your typed text** when a send fails. It also blocks a double-send and limits text to 4096 characters.
- **The manager "All conversations" toggle now works.** We also removed a cache bug that could show another user's chats after login.
- **The trip-details panel** now has a button to open it on smaller screens (it used to disappear below 1280px).

- **The "Connected" banner** turns amber when the WhatsApp account is not active (it was always green, even when broken).
- **Real-time updates** are now grouped, so a burst of messages no longer reloads the list many times. The trip panel also refreshes on a new message.
- **Follow-up reminders:** the daily digest no longer silences the hourly nudge. Duplicate notifications are now suppressed correctly.
- **Demo data:** the seeder now gives the demo chats to the two demo agents directly, not to random users.
- **New leads:** a lock is now respected, so a fast second message does not create a duplicate lead.
- Smaller fixes: search-aware counters, a route guard for WhatsApp, safe phone-call links, correct date labels, and a fixed template-send memory leak.

1c. Look and feel (theme)

The custom indigo theme had broken 13 places on the open-source pages. We fixed all of them: unreadable red text, white-on-white popovers in dark mode, wrong-colour previews, a purple screen tint on mobile, and more.

1d. Deploy hardening

- Developer mode and server-script mode are now off in the setup scripts.
- The admin password now reads from an environment variable, so a real deploy does not use "admin".
- The demo password can be set by an environment variable.

1e. How we tested

- Backend tests pass: WhatsApp (62), demo seeder (12), exchange rate (16).
- The database migration runs clean.
- The frontend builds and the app opens with no new errors.
- The two confirmed security holes were re-tested live and are now closed.

Part 2 — Proposal: show 10 features, not 90

The product has about 90 features. Most come from the open-source base. A first-time, non-technical user will feel lost. **We propose to show about 10 features for the client and hide the rest.** We can turn any hidden feature back on later, one at a time. The full feature list with a keep/hide mark is in

[demo-package/PARAMA-CRM-Feature-Sheet.pdf](#) .

Our recommended 10 to KEEP

1. WhatsApp Team Inbox (the three-pane shared inbox)
2. Auto lead capture from WhatsApp
3. Round-robin auto-assign to agents
4. Priority and "awaiting reply" pills
5. Travel fields on a lead (destination, dates, group size, budget)
6. Travel status ladder (Proposal Sent → Negotiation → Booked)
7. Leads board (list and kanban)
8. Tasks and Notes on a lead
9. Follow-up reminders and the manager daily digest
10. Notifications, and a light Dashboard

Our recommended HIDE list

Phone systems (Twilio, Exotel), ERPNext/accounting sync, Facebook lead-sync, the web-form builder, SLA policies, the assignment-rules screen, sales hierarchy, data import, the layout editors, client scripts, the raw "Desk" backend, group-by and saved views, "enrich from website", and the first-run setup wizards.

Part 3 — Questions for you (please decide)

We did the security audit and the fixes. Before we simplify the app, we need your decisions. Please answer these.

Q1. Feature list. Look at the keep/hide sheet. Do you agree with the 10 we keep and the rest we hide? Tell us anything to move between the two lists.

Q2. How far to simplify. Should we actually hide the extra features now, or leave everything visible for the demo? We can hide them by: (a) giving agents the "Sales User" role, which removes the admin and integration menus; and (b) removing the unused items from the sidebar.

Q3. Demo data. The demo now has a few webhook-test chats from earlier testing. Should we remove them so the demo data is clean?

Q4. Merge strategy. The fixes touch open-source files, so the next pull from the original repo will show merge conflicts. Do you want us to (a) put the fixes on a branch and open a pull request, or (b) keep them local for now?

Q5. Anything off-limits. Is there any feature we should NOT touch or hide? Tell us before we start.

Two small items we left open (your call)

- A time-zone display fix — we left it, because it breaks a test tool and has no effect on the live site today.
- Narrowing who gets a real-time chat event — a full change would break the manager's shared inbox, so we made only the safe part.

PARAMA CRM handoff · 2026-08-18. Companion files in [demo-package/](#) : AUDIT-REPORT.md (full fix detail), PARAMA-CRM-Feature-Sheet.pdf (keep/hide list), PARAMA-CRM-Manual.pdf (client onboarding), PARAMA-CRM-demo.mp4 (product tour).